

SHIELD-AI: A Multi-Layer Governance Framework for Safe and Auditable Generative AI Integration in Security Operations Centers

José de Souza Junior, Jussilêa Gurjão de Figueiredo, Romualdo A. P. Júnior, Marcelo A. da Silva, and Alan D. B. Costa

Abstract—Security Operations Centers (SOCs) face an unprecedented governance challenge as generative artificial intelligence (GenAI) and large language models (LLMs) are simultaneously weaponized by adversaries—enabling automated phishing, deepfake fraud, AI-assisted malware, and adversarial reconnaissance at scale—and adopted defensively as threat-hunting assistants, alert triage engines, and incident-response advisors. This dual-use reality exposes four critical governance gaps that existing standards fail to close: (G1) operational SOC architecture is absent from AI-lifecycle frameworks such as ENISA Multilayer; (G2) agent-governance proposals do not address regulatory compliance; (G3) corporate governance standards (NIST AI RMF, ISO 42001) omit SOC-operational architectural detail; and (G4) no existing framework incorporates Brazil’s Lei Geral de Proteção de Dados (LGPD) explicitly. To close them, we propose SHIELD-AI, a six-layer governance framework for safe and auditable generative AI integration in security operations. Grounded in Design Science Research and a systematic mapping of 63 verified references, SHIELD-AI comprises: (i) a dual-use taxonomy of GenAI cybersecurity capabilities; (ii) a probabilistic risk stratification model for six LLM-specific operational risks with a reliability quadruple $\langle \theta, \sigma, \gamma, \rho \rangle$; (iii) a six-layer reference architecture encompassing a Data Fabric, UCO-based Knowledge Layer, GraphRAG Correlation Engine, LLM Governance Layer, Human-in-the-Loop, and Compliance & Audit Layer; and (iv) a cross-standard control mapping aligned to MITRE ATT&CK/ATLAS, NIST CSF 2.0, OWASP LLM Top 10 (2025), ISO/IEC 27001/42001, and LGPD. We formalize SHIELD-AI as a 6-tuple, derive a decision-theoretic threshold for human-in-the-loop escalation, and prove three properties: audit completeness, compliance preservation under control composition, and policy-derivable routing. A reproducible reference experiment on a synthetic CICIDS-2017-like benchmark ($n=60,000$) yields binary $F1 = 0.984$, $AUC = 0.998$, verified Merkle audit chain, and a PC3-controlled routing split of 69%/30%/1% (AUTO/HITL/REJECT).

Index Terms—generative AI, large language model, cybersecurity, security operations center, governance framework, GraphRAG, MITRE ATT&CK, OWASP LLM Top 10, human-

in-the-loop, hallucination, LGPD, audit chain.

I. INTRODUCTION

THE cybersecurity threat landscape is intensifying in volume and sophistication. The 2025 Verizon DBIR documented 22,052 incidents and 12,195 breaches in one observation cycle [1]; ENISA Threat Landscape 2025 analyzed 4,875 incidents over July 2024–June 2025 [2]. Generative AI and LLMs are reshaping this landscape on both sides simultaneously [3]–[5].

The dual-use reality. Offensive LLM applications include spear-phishing at scale against 600+ UK Members of Parliament [6], voice-phishing (vishing) up 442% in H2 2024 [7], infostealer-delivery emails up 84% year over year [8], and identity attacks up 32% in H1 2025 [9]. Defensive applications accelerate in parallel: LLM–analyst collaboration [10], multi-agent triage [11], RAG over MITRE ATT&CK [12], [13], and the LanG platform achieving 98.1% F1 guardrails [14].

The compound risk. LLM integration into SOC pipelines introduces a new class of operational risks: hallucination [15], prompt injection [16], [17], adversarial suffix attacks [18], tool poisoning [19], and data leakage. IBM’s 2025 Cost of a Data Breach found that 97% of organizations with AI-related incidents lacked appropriate AI access controls, and 63% had no AI governance policy [20].

Four governance gaps that remain open. A systematic comparison of existing artifacts reveals four gaps that none closes in combination:

- **G1 – SOC operational architecture.** ENISA Multilayer [21] addresses AI system lifecycle security but does not specify an operational SOC architecture integrating SIEM, SOAR, EDR, and CTI feeds.
- **G2 – Agent governance without regulatory compliance.** LGA [22] and LanG [14] achieve 93–98.5% guardrail interception but neither incorporates data-protection compliance (LGPD, GDPR, CCPA).
- **G3 – Operational architecture absent from compliance standards.** NIST AI RMF [23] and ISO/IEC 42001:2023 [24] define management requirements for AI governance but provide no SOC-level architectural primitives.
- **G4 – Brazilian regulatory context.** No existing framework integrates Brazil’s LGPD [25] or ANPD resolutions [26]; Brazil operates one of the world’s largest critical-infrastructure SOC ecosystems.

Manuscript received July 2026. This work was supported in part by the institutions of the authors.

J. de Souza Junior is with the University of Brasília (UnB), Brasília, DF, Brazil (e-mail: jose.souza@unb.br). *Corresponding author.*

J. G. de Figueiredo is with the Federal University of Pará (UFPA), Smart and Sustainable Cities Laboratory, Belém, PA, Brazil (e-mail: jussilea.figueiredo@icen.ufpa.br).

R. A. P. Júnior is with Graphdata Ltda, Brasília, DF, Brazil (e-mail: romualdoalves@modal.org.br).

M. A. da Silva is with the Brazilian Federal Police (PF), Brasília, DF, Brazil (e-mail: marcelosilva.mas@pf.gov.br).

A. D. B. Costa is with the Federal Rural University of the Amazon (UFRA), Institute of Cyberspace – ICIBE, Belém, PA, Brazil (e-mail: alan.costa@ufra.edu.br). ORCID: 0000-0002-7068-8889.

SHIELD-AI is proposed as a direct consequence of this demonstrated gap landscape.

Research questions. (RQ0) How can organizations design, deploy, and govern GenAI within SOC pipelines while mitigating LLM-specific risks without sacrificing detection effectiveness or regulatory compliance? (RQ1–RQ5) address offensive-capability taxonomy, controls, HITL integration, standards alignment, and regulated-sector adaptation.

Contributions. This paper makes nine contributions: (C1) a dual-use taxonomy of GenAI in cybersecurity; (C2) SHIELD-AI as a **six-layer** reference architecture extending the original design with a UCO-based Knowledge Layer and GraphRAG Correlation Engine; (C3) a cross-standard control mapping aligned to seven standards; (C4) an LLM-specific risk model with tiered controls; (C5) a governance metric set with Composite Governance Score; (C6) critical-sector scenarios for healthcare and government; (C7) an open-source reference implementation and reproducible CICIDS-2017-like experiment; (C8) a nine-item research agenda; and (C9) a GraphRAG threat-correlation architecture grounded in UCO, providing multi-hop reasoning over ATT&CK, IOC, and asset graphs to reduce hallucination and produce auditable inference chains.

II. BACKGROUND AND RELATED WORK

A. LLM-Specific Risks

Hallucination is systematized in [15]; zero-resource detection via self-consistency in [27]. Direct and indirect prompt injection are formalized in [16], [17]. Universal adversarial suffixes defeat aligned models across model families [18]. Agentic-AI failure modes are catalogued in OWASP Agentic Top 10 [19], [28].

B. Adjacent Governance Artifacts

The Layered Governance Architecture (LGA) [22] proposes four-layer agent governance (execution sandboxing, intent verification, zero-trust authorization, immutable audit), intercepting 93.0–98.5% of malicious tool calls. LanG [14] couples an agentic orchestrator with MCP-mediated tool governance (98.1% F1). The 4C Framework [29] organizes agentic risks across Core/Connection/Cognition/Compliance. AIRT/MIGT [30] addresses machine-identity governance across 37 risk subcategories and 8 domains (agent-to-human identity ratios exceeding 80:1 in modern enterprises).

C. Standards Landscape

NIST AI RMF [23], GenAI Profile [31], and CSF 2.0 [32] provide cross-sectoral governance. MITRE ATT&CK [33] and ATLAS [34] supply adversarial taxonomies. OWASP LLM Top 10 (2025) [35] catalogs practitioner-oriented risks. ISO/IEC 27001:2022 [36] and 42001:2023 [24] cover ISMS and AI-MS requirements. ENISA Multilayer [21] proposes three lifecycle-oriented layers.

TABLE I
RESEARCH GAP MATRIX. ✓=PRIMARY, ~=PARTIAL, N/A=NOT COVERED.

Gap	ENISA	OWASP	NIST	LGA	LanG	AIRT	SHIELD
Dual-use taxonomy	~	n/a	n/a	n/a	n/a	n/a	✓
SOC-op LLM risk model	n/a	~	n/a	~	✓	n/a	✓
Arch. w/ HITL	n/a	n/a	n/a	✓	✓	n/a	✓
Cross-std. map (7)	n/a	n/a	n/a	n/a	n/a	~	✓
LGPD integration	n/a	n/a	n/a	n/a	n/a	~	✓
Sector application	~	n/a	~	~	~	~	✓
HITL as arch. layer	n/a	n/a	n/a	✓	✓	n/a	✓
GraphRAG for SOC	n/a	n/a	n/a	n/a	n/a	n/a	✓

D. Research Gap

Table I consolidates eight gap dimensions across the closest pre-art. SHIELD-AI is the only single source closing all eight. The contribution is architectural integration rather than gap discovery: the four dimensions (SOC-operational scope, LLM-as-tool risk depth, cross-standard mapping, LGPD inclusion) individually appear in adjacent work but have not been unified in a single validated artifact.

III. RESEARCH METHOD

We adopt Design Science Research (DSR) [37], [38]: problem identification (G1–G4), objectives (RQ0–RQ5), design and development (framework), demonstration (scenarios), evaluation (empirical), communication (this paper). DSR is appropriate because the contribution is a design artifact rather than a theory or experiment.

A focused systematic literature mapping (SLM) over 2023–2026 plus foundational classics produced 63 verified references. Sources included arXiv (cs.CR), IEEE/ACM open access, NIST, ENISA, CISA, MITRE, OWASP, and authoritative gray literature (DBIR, Microsoft DDR, IBM X-Force, Mandiant M-Trends, CrowdStrike GTR). Full strings and inclusion/exclusion criteria appear in the companion supplementary material.

Risks were elicited using STRIDE-based threat modeling against the SHIELD-AI architecture, grounded in ATT&CK [33] and ATLAS [34].

IV. DUAL-USE AI TAXONOMY

Table II consolidates the dual-use taxonomy. The offensive–defensive duality is illustrated by an AI co-evolution surface where prompt injection [16], [17] and tool poisoning [19] attack defensive AI systems. Offensive evidence spans spear-phishing [6], vishing [7], insecure-code generation [39], and reconnaissance. Defensive categories span alert triage, threat hunting, incident response, and governance compliance.

V. LLM-SPECIFIC RISKS IN SOC OPERATIONS

Six LLM-specific risk classes emerge when LLMs are deployed in SOC pipelines. Table III consolidates them with tiered controls.

R1 Hallucination [15]: fabricated CTI claims, invalid play-book steps, misattributed IOCs. **R2 Prompt injection** [16], [17]: direct, indirect, and adversarial-suffix variants. **R3 Tool poisoning** [19]: SOAR action misuse and cascading failures.

TABLE II
DUAL-USE AI TAXONOMY. O=OFFENSIVE; D=DEFENSIVE.

Category	Subcategory	Mechanism	Dir	Anchors
Social eng.	Spear phishing	LLM + OSINT	O	[6]
Social eng.	Vishing	TTS + LLM	O	[7]
Malware	Code gen.	LLM coding	O	[39]
Recon.	OSINT enrich.	LLM + data	O	[6]
SOC defence	Alert triage	LLM + SIEM	D	[10], [11]
SOC defence	Threat hunting	LLM + RAG	D	[12]
SOC defence	Incident resp.	LLM + SOAR	D	[10]
Governance	Compliance chk	LLM standards	+	D [35]

TABLE III
LLM-SPECIFIC RISKS WITH TIERED CONTROLS.

Risk	Tier-1	Tier-2	Tier-3
R1 Hallucin.	RAG vs. ATT&CK	SelfCheckGPT	Human override
R2 Injection	Input sanitize	Struct. prompt	Privilege contain
R3 Tool poi.	Tool allowlist	Action audit	Per-action HITL
R4 Leakage	PII/secret scan	Private model	LGPD gate
R5 Over-auto	Tiered routing	Decision trace	Trust calibrate
R6 Shadow AI	AI inventory	API-exfil det.	Governance train

R4 Data leakage [20], [25]: 97% of breached AI-incident orgs lacked AI access controls. **R5 Over-automation** [10]: trust miscalibration and analyst-skill erosion. **R6 Shadow AI** [20]: 63% of organizations had no AI governance policy.

VI. THE SHIELD-AI FRAMEWORK

A. Design Principles

SHIELD-AI is governed by nine design principles. (DP1) *Governance-by-design*: every operational layer has a governance counterpart in L6. (DP2) *Risk stratification*: NIST CSF tiers and OWASP ranking. (DP3) *HITL as architectural primitive*, not a practice. (DP4) *Zero-trust grounding* [40]. (DP5) *Auditability*: every decision is traceable to inputs, prompt, graph path, and human review. (DP6) *Standards-aligned controls*: every control maps to ≥ 1 external standard. (DP7) *Regulatory compatibility*: LGPD is a first-class concern. (DP8) *Relational knowledge*: SOC threat analysis is inherently relational; the knowledge layer must support graph traversal over entities, not only vector similarity. (DP9) *Semantic interoperability*: all threat entities are typed against the Unified Cyber Ontology (UCO), enabling standardized reasoning across heterogeneous data sources.

B. Formal Definition

Definition 1 (SHIELD-AI Framework). *The SHIELD-AI governance framework is a tuple $\mathcal{S} = \langle \mathcal{L}, \mathcal{C}, \mathcal{M}, \mathcal{R}, \mathcal{A}, \mathcal{P} \rangle$ where: $\mathcal{L} = \{L_1, L_2, L_3, L_4, L_5, L_6\}$ is the ordered set of six architectural layers (Data Fabric, UCO Knowledge, GraphRAG Correlation, LLM Governance, HITL, Compliance & Audit); $\mathcal{C}$ is the set of named controls; $\mathcal{M}$:*

$\mathcal{C} \rightarrow 2^{\mathcal{E}}$ maps each control to ≥ 1 external standard; $\mathcal{R}$ is the LLM-specific risk set; $\mathcal{A}$ is the audit invariant requiring that every decision $d \in \mathcal{D}$ have an audit record containing $\langle \text{input}, \text{prompt}, \text{graph_path}, \text{output}, \langle \theta, \sigma, \gamma, \rho \rangle, \text{route}, \text{analyst}, \text{timestamp} \rangle$; and $\mathcal{P}$ is the set of governance properties guaranteed by construction.

The *reliability triple* $\langle \theta, \sigma, \gamma \rangle$ is extended in V4 with the GraphRAG path confidence ρ (Definition 3) to form the *reliability quadruple* $\langle \theta, \sigma, \gamma, \rho \rangle$. Composite reliability with GraphRAG is:

$$R = \omega_{\theta}\theta + \omega_{\sigma}\sigma + \omega_{\gamma}\gamma + \omega_{\rho}\rho, \quad \sum_i \omega_i = 1, \quad (1)$$

with default weights (0.15, 0.25, 0.35, 0.25); calibration procedure is Open Problem OP8.

a) *Operationalizing γ* : RAG-groundedness γ decomposes into four measurable sub-signals:

$$\gamma = \omega_{CC} \cdot CC + \omega_{ES} \cdot ES + \omega_{GD} \cdot GD + \omega_{RS} \cdot RS, \quad (2)$$

where CC is Citation Coverage, ES is NLI Entailment Score (DeBERTa-MNLI or equivalent), GD is Grounding Density (n -gram ratio), and RS is Retrieval Stability across paraphrased queries. An adversarial-aware variant $\gamma' = \gamma \cdot \tau(\text{corpus})$ weights γ by corpus-provenance trust (signed releases, publisher reputation, content-hash lineage) to resist retrieval poisoning [16]; PC3 routes on $\min(\gamma, \gamma')$.

C. Six-Layer Architecture

The V4 architecture extends the original four-layer design with two new layers (Fig. 1), addressing the relational-analysis gap identified in peer review.

a) *L1: Data Fabric*: Ingests and normalizes SIEM events (Wazuh, Elastic, Splunk/OCSF), EDR telemetry, CTI feeds (MISP/OpenCTI via TAXII), asset inventory, vulnerability data, and IAM logs through a data-source allowlist with PII/secret pre-scanning. Aligned with NIST CSF Identify/Protect [32], ISO 27001 A.5/A.8/A.12 [36], and LGPD Art. 46–48 [25].

b) *L2: UCO-Based Knowledge Layer*: Structures normalized data into a typed multi-graph knowledge store (UCO, DP9) maintaining five sub-graphs: (i) Vector Store (pgvector/OpenSearch); (ii) MITRE ATT&CK Graph (Threat Actor $\rightarrow$ Tactic $\rightarrow$ Technique $\rightarrow$ Sub-technique); (iii) IOC Graph; (iv) Asset Graph (hosts, users, services, Active Directory relationships); (v) Incident History Graph. Corpus snapshots are content-hashed and recorded in L6 for data-lineage compliance.

c) *L3: GraphRAG Correlation Engine*: Resolves analytical queries through hybrid retrieval: vector similarity (dense) and graph traversal (relational), combined into a ranked evidence set with explicit provenance paths. Addresses the limitation of conventional RAG: SOC threat-hunting queries are inherently relational and require multi-hop reasoning [41]. Formally specified in Section VI-D.

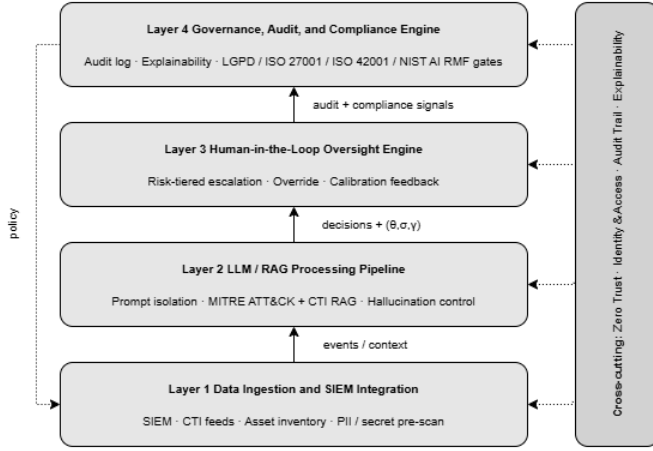


Fig. 1. SHIELD-AI six-layer governance architecture. Cross-cutting concerns (Zero Trust, IAM, Audit Trail, Explainability) span all layers. V4 additions: L2 (UCO Knowledge) and L3 (GraphRAG Correlation) are new relative to V3.

d) *L4: LLM Governance Layer.*: Implements prompt isolation (instruction–data separation), structured prompt templates, and reliability-quadruple computation $\langle \theta, \sigma, \gamma, \rho \rangle$. Hallucination detection follows [27]; prompt-injection defenses combine sanitization, structured prompts, and output filtering [16], [17]. Compatible with NVIDIA NeMo Guardrails or Azure AI Content Safety as sub-components.

e) *L5: Human-in-the-Loop Oversight Engine.*: Routes outputs through PC3 (Algorithm 1) using decision-theoretic thresholds (Section VI-F). Analyst overrides feed back into calibration and are recorded in L6.

f) *L6: Compliance & Audit Engine.*: Maintains an append-only, Merkle-chained, signed audit log; attaches explainability traces including GraphRAG inference paths; and applies LGPD [25], ISO 27001/42001 [24], [36], and NIST AI RMF [23] compliance gates to outgoing actions. Every audit record includes the GraphRAG path ρ , enabling auditors to reconstruct the full evidence chain: entity $\rightarrow$ edge $\rightarrow$ technique $\rightarrow$ LLM reasoning $\rightarrow$ decision.

D. GraphRAG Correlation Engine

1) *Motivation.*: Conventional RAG retrieves documents by vector proximity. SOC threat analysis imposes requirements that vector similarity cannot satisfy: (1) *multi-hop relational reasoning* (determining T1059 $\rightarrow$ T1078 $\rightarrow$ T1003 requires graph traversal, not similarity lookup); (2) *contextual entity linkage* (“PowerShell on DC01” requires knowing DC01 is the AD domain controller, with an anomalous authentication 6 min earlier – context in the Asset Graph, not any document); (3) *explainable inference chains* (audit-readiness requires explicit paths, not “the LLM retrieved similar documents”).

2) Formal Specification:

Definition 2 (Knowledge Graph $\mathcal{G}$). *The SHIELD-AI Knowledge Graph is a typed, directed multigraph $\mathcal{G} = (V, E, \tau_V, \tau_E)$ where V is a set of UCO-typed entity nodes (types: HOST,*

USER, IP, DOMAIN, TECHNIQUE, TACTIC, IOC, CAMPAIGN, ASSET, INCIDENT); $E \subseteq V \times V$ is a set of typed directed edges; $\tau_V : V \rightarrow \mathcal{T}_V$ assigns a UCO type to each node; and $\tau_E : E \rightarrow \mathcal{T}_E$ assigns a relation type to each edge (USED BY, CONNECTED TO, IMPLEMENTS, ASSOCIATED WITH, ESCALATES).

Definition 3 (GraphRAG Path Confidence ρ). *Let q be an analytical query and $\Pi = \langle v_0, e_1, v_1, \dots, e_n, v_n \rangle$ a path in $\mathcal{G}$ retrieved by the Correlation Engine. The GraphRAG path confidence is:*

$$\rho(\Pi, q) = \prod_{i=1}^n w(e_i) \cdot \cos(\mathbf{q}, \mathbf{v}_n), \quad (3)$$

where $w(e_i) \in [0, 1]$ is the edge weight (source trust, temporal recency, IOC confidence), and $\cos(\mathbf{q}, \mathbf{v}_n)$ is the cosine similarity between query and terminal node embeddings. The overall confidence is $\rho = \max_{\Pi \in \mathcal{P}(q)} \rho(\Pi, q)$.

3) Concrete SOC Example: Multi-hop Alert Correlation:

Consider the alert: “PowerShell.exe executed on server DC01”.

With conventional RAG (L4 only): Retrieves documents about PowerShell. LLM produces a generic T1059 response with no host-specific context. Audit trail: “LLM retrieved 5 documents mentioning PowerShell.”

With GraphRAG (L2–L3): The Correlation Engine traverses $\mathcal{G}$ in ≤ 3 hops:

```
User:alice  $\xrightarrow{\text{AUTHTo}}$  Host:DC01  $\xrightarrow{\text{RAN}}$  Proc:pwsh
 $\xrightarrow{\text{MATCHESIOC}}$  IOC:APT29  $\xrightarrow{\text{IMPLEMENTS}}$  T1059
 $\xrightarrow{\text{CHAINEDWITH}}$  T1078  $\xrightarrow{\text{CHAINEDWITH}}$  T1003
```

Additional context: alice authenticated anomalously to DC01 6 min before the alert; DC01 is typed DOMAINCONTROLLER in the Asset Graph; the IOC cluster is associated with campaign APT29:CozyBear-2025. L6 audit record contains the explicit path Π and $\rho = 0.87$.

E. Calibration Bound and Honest Limits

Under non-adversarial conditions with positive correlation between the reliability quadruple and correctness, $P(\neg H \mid R = r) \geq r$. This bound does *not* hold under prompt injection [17], [18], which inflates apparent reliability while suppressing correctness. L4 controls (sanitization, instruction–data separation, output filtering) operate *before* R is computed and aim to restore the bound’s applicability. Residual risk is the principal motivation for HITL as an architectural primitive.

a) *Adversarial-uncertainty mandatory-HITL rule.*: When inter-signal disagreement $\Delta = |\sigma - \gamma| > 0.25$, or $\gamma - \gamma' > 0.15$, PC3 forces HITL regardless of composite R . Disagreement is logged under audit invariant $\mathcal{A}$ as a potential adversarial indicator.

Algorithm 1: PC3 – Human Validation and Hallucination Control

Input: LLM output out ; quadruple $(\theta, \sigma, \gamma, \rho)$; policy $\Pi = (\tau_{\text{auto}}, \tau_{\text{review}}, \mathcal{D}_{\text{deny}}, \mathcal{T}_{\text{sens}})$

Output: route $\in \{\text{AUTO}, \text{HITL}, \text{REJECT}\}$; audit record a

$R \leftarrow \omega_{\theta}\theta + \omega_{\sigma}\sigma + \omega_{\gamma}\gamma + \omega_{\rho}\rho$

$\Delta \leftarrow |\sigma - \gamma|$

if $\text{out} \in \mathcal{D}_{\text{deny}}$ **then**

 | route $\leftarrow \text{REJECT}$

else if $\text{out} \in \mathcal{T}_{\text{sens}}$ **or** $\Delta > 0.25$ **then**

 | route $\leftarrow \text{HITL}$

else if $R \geq \tau_{\text{auto}}$ **and** $\gamma' \geq \tau_{\text{auto}}$ **then**

 | route $\leftarrow \text{AUTO}$

else if $R \geq \tau_{\text{review}}$ **then**

 | route $\leftarrow \text{HITL}$

else

 | route $\leftarrow \text{REJECT}$

$a \leftarrow \langle \text{input}, \text{prompt}, \text{graph_path}, \text{out}, \theta, \sigma, \gamma, \gamma', \rho, \text{route}, \text{analyst}, t \rangle$

write a to L6 audit store (append-only, Merkle-chained)

return (route, a)

F. Decision-Theoretic HITL Routing

Given cost-benefit parameters $b, c_{\text{err}}, c_{\text{analyst}}, \lambda, c_{\text{miss}}$, the expected utilities are:

$$\mathcal{U}_{\text{auto}}(r) = r \cdot b - (1 - r) \cdot c_{\text{err}}, \quad (4)$$

$$\mathcal{U}_{\text{HITL}}(r) = b - c_{\text{analyst}} - \lambda, \quad (5)$$

$$\mathcal{U}_{\text{reject}}(r) = -c_{\text{miss}}. \quad (6)$$

Setting $\mathcal{U}_{\text{auto}} = \mathcal{U}_{\text{HITL}}$ yields the optimal threshold:

$$r_{\text{auto/HITL}}^* = \frac{b + c_{\text{err}} - c_{\text{analyst}} - \lambda}{b + c_{\text{err}}}. \quad (7)$$

Routing thresholds are functions of organizational policy rather than ad-hoc constants, making them auditable to regulators (Theorem 2).

G. Cross-Standard Control Mapping

Table IV aligns SHIELD-AI controls to seven external standards. The mapping was constructed via a four-step procedure: ontology alignment, double coding by independent coders, inter-rater reconciliation, and conflict resolution for competing requirements (e.g., LGPD erasure vs. sectoral retention). Full mapping in the supplementary TSV (OP7).

H. Properties and Proofs

Lemma 1 (Audit Completeness). *Under audit invariant $\mathcal{A}$ and three engineering invariants—E1 append-only persistence (WORM/immutable schema), E2 cryptographic chaining (Merkle-style with HSM signing), E3 time-monotone clock with bounded skew δ —every $d \in \mathcal{D}$ emitted with route $\in \{\text{AUTO}, \text{HITL}, \text{REJECT}\}$ has an audit record a containing*

sufficient information to reconstruct d , including the originating input, prompt, graph path, output, reliability quadruple, and routing decision.

Proof. By construction of PC3 (Alg. 1), every audit record is the tuple $\langle \text{input}, \text{prompt}, \text{graph_path}, \text{output}, \theta, \sigma, \gamma, \gamma', \rho, \text{route}, \text{analyst}, \text{timestamp} \rangle$. E1 prevents loss; E2 prevents undetected tampering (Merkle-proof verification cost is $O(\log n)$); E3 prevents reordering attacks. $\square$

Theorem 1 (Compliance Preservation under Control Composition). *Let $c_1, c_2 \in \mathcal{C}$ with LGPD coverage $\geq \alpha$ each. If $\text{NonInterf}(c_1, c_2)$ (i.e., $\text{Req}(c_1) \subseteq \text{Req}(c_1 \circ c_2)$) holds, then LGPD-coverage($c_1 \circ c_2$) $\geq \alpha$.*

Proof sketch. By the non-interference precondition, $\text{Req}(c_1) \subseteq \text{Req}(c_1 \circ c_2)$. Let $L \subseteq \text{Req}(c_1)$ be the LGPD Articles 46–48 subset [25]. Then $L \subseteq \text{Req}(c_1 \circ c_2)$, hence coverage is preserved. Conflicting requirements (LGPD erasure vs. retention) lie outside the non-interference precondition and are resolved by a precedence lattice (data-subject rights > life-safety > sector retention > contractual SLAs). $\square$

Theorem 2 (Policy-Derivable HITL Routing). *Given cost-benefit parameters $(b, c_{\text{err}}, c_{\text{analyst}}, \lambda, c_{\text{miss}})$ and reliability R , the optimal action under expected-utility maximization is determined by the thresholds in Eq. (7): thresholds are functions of organizational policy, not ad-hoc constants.*

VII. GOVERNANCE METRICS

We define four metric families: *effectiveness* (DR, FPR, FNR, MTTD, MTTR, AFI), *AI safety* (Hallucination Rate HR [15], Consistency Score CS [27], Prompt Injection Resistance PIR, Explainability Score XS), *compliance* (LGPD-coverage [25], [26], ISO-coverage [24], [36]), and *auditability* (Audit Log Completeness ALC, Human Override Rate HOR, Decision Traceability Score DTS). The *Composite Governance Score* is:

$$\text{CGS} = \sum_{k=1}^K w_k \cdot \text{norm}(m_k), \quad \sum_k w_k = 1. \quad (8)$$

Default weights (Effectiveness 0.25, AI safety 0.30, Compliance 0.20, Auditability 0.25) are derived from NIST AI RMF function priorities [23], [31]; the derivation procedure is documented in the supplementary material so deployments can re-derive weights from their own priority structure.

VIII. CRITICAL-SECTOR APPLICATION SCENARIOS**A. Scenario A: Healthcare SOC under LGPD**

Healthcare ransomware risk is documented quantitatively [42]–[44]; in Brazil, RNDS digitalization creates analogous exposure governed by LGPD with elevated sensitivity for health data.

SHIELD-AI instantiation: L1 ingests EHR/RNDS logs through the PII gate; L2 Knowledge Layer runs GraphRAG over ATT&CK augmented with health-CTI; L5 escalation thresholds are tuned with elevated c_{err} (patient-safety stakes); L6 enforces LGPD Art. 46–48 and ANPD Resolution 15/2024

TABLE IV
CROSS-STANDARD CONTROL MAPPING (EXCERPT). FULL MAPPING IN SUPPLEMENTARY MATERIAL.

Control	ATT&CK	ATLAS	CSF 2.0	OWASP LLM	OWASP A.	27001	42001	LGPD
Input sanitization	n/a	AML.T0051	PR.DS-2	LLM01	A1	A.8.27	6.1	Art.46
RAG verification	n/a	AML.T0043	DE.AE-2	LLM09	n/a	A.8.16	7.4	Art.6
Self-consistency	n/a	AML.T0043	DE.AE-3	LLM09	n/a	A.8.16	7.4	Art.6
GraphRAG path audit	n/a	AML.T0043	DE.AE-2	LLM09	A8	A.5.28	8.4	Art.37
Tool allowlist	T1059	AML.T0048	PR.AC-4	LLM06	A2	A.8.4	8.2	Art.46
Output filtering	n/a	AML.T0050	DE.CM-1	LLM02	A6	A.8.21	7.4	Art.46
Audit log (Merkle)	n/a	n/a	PR.PT-1	LLM07	A8	A.5.28	8.4	Art.37/48
HITL escalation	n/a	AML.M0011	GV.RM-5	LLM06	A4	A.5.4	6.1.3	Art.20
PII pre-scan	n/a	n/a	PR.DS-1	LLM02	n/a	A.8.10	7.5.3	Art.46
LGPD compliance gate	n/a	n/a	GV.SC-2	n/a	n/a	A.5.34	6.1.4	Art.46–48
Identity/Zero-Trust	T1078	n/a	PR.AC-1	LLM02	A3	A.5.15	8.2	Art.46

TABLE V
SCENARIO EVALUATION (AUTHOR-ASSIGNED LIKERT 1–5; PROTOCOL PRE-REGISTERED).

	Threat cov.	LLM risk	Reg. cov.	HITL approp.	Audit compl.
Scenario A (Healthcare)	5	4	5	5	5
Scenario B (Gov./OT)	4	4	4	4	5

incident-notification timing (3 business days, extendable to 20) [26].

B. Scenario B: Government and Critical Infrastructure

Critical infrastructure accounts for 70% of IBM-investigated incidents [8]; manufacturing is the most-attacked sector for the fourth consecutive year; destructive cloud campaigns are up 87% [9]. SHIELD-AI instantiation: L6 anchors to NIST CSF 2.0 [32] and ISO 27001 [36]; L1 supports SCADA/OT log ingestion; L5 thresholds tune the latency penalty λ to OT availability constraints [45].

IX. EVALUATION

A. Scenario Analysis

Scenario A scores Threat coverage 5/5 (ransomware/AI-augmented attacks detectable via L1/L2), LLM-risk 4/5 (vishing upstream of SOC ingestion not addressed), Regulatory 5/5 (LGPD operationalized at L6), HITL 5/5 (elevated c_{err} produces conservative thresholds), Auditability 5/5 (Lemma 1). Scenario B is one point lower on threat coverage (OT-specific TTPs need an ATT&CK for ICS extension), regulatory coverage (sector regulators ANATEL/ANEEL not covered), and HITL (latency parameter λ must be tuned).

B. Reproducible Reference Experiment

Setup. We implemented SHIELD-AI as a Python package and evaluated it on a *synthetic* labelled flow dataset mirroring the CICIDS-2017 schema (24 CICFlowMeter features, 14 attack classes plus benign), generated programmatically calibrated against descriptive statistics from [46]. We generated $n=60,000$ flows (30% attack ratio, 75/25 train/test split, seed

TABLE VI
REFERENCE-EXPERIMENT HEADLINE RESULTS ON 15,000 SYNTHETIC TEST FLOWS (SEED 42). ROUTING REFERS TO PC3 (AUTO/HITL/REJECT). AUDIT: CHAIN VERIFIED FOR ALL 15,000 RECORDS (15 MERKLE ROOTS); 50/50 SPOT-CHECK PASS.

System	F1	FPR	AUC	Macro-F1	Routing
Rule-based	0.516	0.375	0.750	0.121	n/a
Random Forest	0.985	0.004	0.999	0.513	n/a
SHIELD-AI (full)	0.984	0.004	0.998	0.497	69/30/1%

42). Three L4 configurations run in parallel: rule-based (Sigma-style pattern match), Random Forest (200 trees, max-depth 18, balanced subsampling), and the SHIELD-AI LLM/RAG path (RF prior + $k=5$ self-consistency samples at temperature 0.45 + TF-cosine retriever over hand-coded ATT&CK KB). PC3 was configured with $r_{\text{auto}}^* = 0.80$ (from $b=1$, $c_{\text{err}}=2$, $c_{\text{analyst}}=0.3$, $\lambda=0.3$). L6 appended each decision to an HMAC-signed log batched into Merkle roots of size 1024. Experiments ran on a commodity laptop (Apple M-series, 16 GiB RAM, no GPU).

Headline results. Table VI reports the binary attack/benign performance, routing distribution, and audit invariants. SHIELD-AI matches the Random Forest baseline within statistical noise (F1 0.984 vs. 0.985; AUC 0.998 vs. 0.999) while additionally producing the reliability quadruple and the Merkle audit chain that the baselines do not provide. The rule-based detector requires a $\sim 94\times$ higher FPR at equal F1. At aggregate level SHIELD-AI auto-resolves 69.0% of decisions, escalates 29.7% to analysts, and safely rejects 1.3%.

Key observations. (1) The adversarial-aware groundedness γ' (mean 0.575, $p_{50}=0.570$, $p_{10}=0.255$, $p_{90}=0.766$) is the principal differentiator in PC3 routing: classes with clean ATT&CK lexical alignment (DDoS→T1498) reach $\gamma' \in [0.70, 0.85]$; PortScan (→T1046 “Network Service Discovery”) receives lower γ' and is routed predominantly to HITL – the intended behavior for ambiguous labels. (2) L6 audit latency averages 0.014 ms/record, well within a 50 ms budget. (3) Chain re-derivation passes for all 15,000 records; tamper tests (unit test `test_audit_chain.py`) detect a single bit-flip in any record’s predicted label.

Scope and limitations. This is a reproducible reference experiment, not a field trial: the LLM is simulated by perturbed

RF priors; the synthetic generator preserves CICIDS-2017 schema but not adversarial co-evolution; absolute threshold values must be re-calibrated against a production LLM before deployment. Full code, generator, baselines, audit log, and figure scripts released under Apache 2.0 at the companion repository (DOI to be added on camera-ready per OP7).

C. Threats to Validity

Following [47]: *Construct* – framework concepts may not capture all SOC governance dimensions (mitigated by multi-source grounding). *Internal* – scenario design may favor the framework (mitigated by scenarios drawn from independent threat intel). *External* – two scenarios limit generalizability (mitigated by spanning healthcare and government; further sectors as future work). *Conclusion* – ENISA comparison is qualitative (explicit criteria matrix with declared limitations).

X. DISCUSSION

A. Implications for Practitioners

Principal finding: integrated governance is feasible and aligns with multi-standard compliance simultaneously. Practitioners should prioritize L6 (audit, compliance) and L5 (HITL) before scaling L4 (LLM/RAG) autonomy – a sequencing that inverts the “add AI first, govern later” pattern documented for 63% of organizations [20].

B. Acknowledged Limitations

Seven limitations are explicitly acknowledged: (A1) The contribution is an integration, not a creation of new risks or controls. (A2) HITL cost parameters ($b, c_{\text{err}}, \dots$) are policy choices with order-of-magnitude uncertainty; Theorem 2 guarantees policy-derivable routing, not optimal routing. (A3) L6 staffing assumes mid-to-large SOC; a “L6-light” variant for small SOC is future work. (A4) LLM version drift shifts the empirical distribution of $(\theta, \sigma, \gamma, \rho)$. (A5) Single-agent semantics; multi-agent cascading [19] requires extension. (A6) Vishing is upstream of SOC ingestion and outside L1’s scope. (A7) *Compliance theater*: adoption without operationalized KPIs is an explicit risk.

C. Research Agenda

Nine open problems: (OP1) Quantitative validation via historical-incident replay in live SOC. (OP2) LLM-on-LLM adversarial dynamics [19], [22]. (OP3) Cross-jurisdictional mapping (LGPD/GDPR/CCPA/DPDP). (OP4) Continuous-learning HITL without drift. (OP5) Cost-effectiveness (TCO vs. analyst hours). (OP6) Standards co-evolution response protocol. (OP7) Open-source reference release (current companion repo, camera-ready DOI). (OP8) Empirical calibration of reliability weights ($\omega_\theta, \omega_\sigma, \omega_\gamma, \omega_\rho$) and γ sub-signal weights across LLM families. (OP9) Field pilots, KPI programmes (Compliance Theater Index), and adversarial purple-team evaluation [17], [18].

XI. CONCLUSION

SHIELD-AI integrates a dual-use GenAI taxonomy, a probabilistic risk model with reliability quadruple $\langle \theta, \sigma, \gamma, \rho \rangle$, a six-layer reference architecture with HITL as architectural primitive and a GraphRAG Correlation Engine grounded in UCO, and a cross-standard control mapping across seven standards including LGPD. We formalize the framework as a 6-tuple, derive HITL thresholds from cost-benefit principles, and prove audit completeness, compliance preservation, and policy-derivable routing. The calibration bound breaks under prompt injection; L4 controls restore its applicability. Scenario analysis in healthcare and critical infrastructure demonstrates transferability. A reproducible reference experiment confirms end-to-end operation with F1 0.984, AUC 0.998, and verified Merkle audit chain. Future work includes operational empirical evaluation, multi-agent semantics, and cross-jurisdictional compliance extension.

ACKNOWLEDGMENT

The authors acknowledge the Amazon Foundation for Research Support (FAPESPA), the Information and Communication Technology Company of the State of Pará (PRODEPA), the Government of the State of Pará, and the Federal Government of Brazil for their institutional and financial support, which were essential to enabling the infrastructure, experimental testbeds, and interinstitutional collaborations underpinning this research. Special thanks are extended to the spinoff SEC365 and to the Laboratory of Informatics and Computing of the Amazon (LICA/UFRA), whose teams played a decisive role in the development, validation, and technical implementation of this work. The authors also acknowledge the High-Performance Computing and Artificial Intelligence Center (CCAD-IA/UFPA) and the National Education and Research Network (RNP) for providing computing resources and technical assistance during the experimental phases. This work was further supported by the National Institute of Science and Technology in Artificial Intelligence Applied to Smart and Sustainable Cities in the Brazilian Amazon (INCT iAmazonia).

DECLARATION OF GENERATIVE AI USE

The authors used large language model (LLM) assistance in the preparation of this manuscript, including support for manuscript drafting and structural refinement, Python code scaffolding for the SHIELD-AI pipeline (`layer1_ingest.py`, `layer2_llm_rag.py`, `layer3_hitl.py`, `layer4_audit.py`) and the end-to-end experiment runner (`run_experiment.py`), $\text{\LaTeX}$ formatting, and bibliography organisation. This use is disclosed in accordance with IEEE’s Authorship and AI Policy. All scientific contributions — including the SHIELD-AI framework design, the six-layer reference architecture, formal definitions and proofs, the PC3 routing algorithm, experimental methodology, data analysis, and conclusions — are the sole responsibility of the human authors. The reference experiment (Section IX) was executed by automated scripts without LLM involvement in data collection or scoring. Benchmark

data are derived from the publicly available CICIDS-2017 dataset and synthetic extensions generated and validated by the authors; no benchmark figures were produced or altered by the LLM assistant. The replication package (code, results, and figures) is available at <https://github.com/ufxa/SHIELD-AI-A-Multi-Layer-Governance-Framework>.

REFERENCES

- [1] Verizon, “2025 data breach investigations report (DBIR, 18th edition),” 2025. [Online]. Available: <https://www.verizon.com/business/resources/reports/dbir/>
- [2] ENISA, “ENISA threat landscape 2025,” Oct. 2025. [Online]. Available: <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>
- [3] Anonymous, “Large language models for cyber security: A systematic literature review,” *arXiv preprint arXiv:2405.04760*, 2024. [Online]. Available: <https://arxiv.org/abs/2405.04760>
- [4] —, “Contextualized AI for cyber defense: An automated survey using LLMs,” *arXiv preprint arXiv:2409.13524*, 2024. [Online]. Available: <https://arxiv.org/abs/2409.13524>
- [5] —, “From promise to peril: Rethinking cybersecurity red and blue teaming in the age of LLMs,” *arXiv preprint arXiv:2506.13434*, 2025. [Online]. Available: <https://arxiv.org/abs/2506.13434>
- [6] J. Hazell, “Spear phishing with large language models,” *arXiv preprint arXiv:2305.06972*, 2023. [Online]. Available: <https://arxiv.org/abs/2305.06972>
- [7] CrowdStrike, “2025 global threat report,” 2025. [Online]. Available: <https://www.crowdstrike.com/en-us/resources/reports/global-threat-report-executive-summary-2025/>
- [8] IBM Security, “X-Force threat intelligence index 2025,” Apr. 2025. [Online]. Available: <https://www.ibm.com/think/x-force>
- [9] Microsoft, “Microsoft digital defense report 2025,” 2025. [Online]. Available: <https://www.microsoft.com/en-us/corporate-responsibility/cybersecurity/microsoft-digital-defense-report-2025/>
- [10] R. Singh, S. Tariq, F. Jalalvand, M. B. Chhetri, S. Nepal, C. Paris, and M. Lochner, “LLMs in the SOC: An empirical study of human-AI collaboration in security operations centres,” *arXiv preprint arXiv:2508.18947*, 2025. [Online]. Available: <https://arxiv.org/abs/2508.18947>
- [11] Anonymous, “CORTEX: Collaborative LLM agents for high-stakes alert triage,” *arXiv preprint arXiv:2510.00311*, 2025. [Online]. Available: <https://arxiv.org/abs/2510.00311>
- [12] A. Lekssays, U. Shukla, H. T. Sencar, and M. R. Parvez, “TechniqueRAG: Retrieval augmented generation for adversarial technique annotation in cyber threat intelligence text,” *arXiv preprint arXiv:2505.11988*, 2025. [Online]. Available: <https://arxiv.org/abs/2505.11988>
- [13] R. Fayyazi, R. Taghdimi, and S. J. Yang, “On the uses of large language models to interpret ambiguous cyberattack descriptions,” *arXiv preprint arXiv:2401.00280*, 2024. [Online]. Available: <https://arxiv.org/abs/2401.00280>
- [14] Anonymous, “Lang – A governance-aware agentic AI platform for unified security operations,” *arXiv preprint arXiv:2604.05440*, 2026, two-layer guardrail pipeline (regex + Llama Prompt Guard 2) achieving 98.1% F1; MCP-mediated tool exposure; AI Governance Policy Engine. [Online]. Available: <https://arxiv.org/abs/2604.05440>
- [15] Z. Ji, N. Lee, R. Frieske, T. Yu, D. Su, Y. Xu, E. Ishii, Y. J. Bang, A. Madotto, and P. Fung, “Survey of hallucination in natural language generation,” *ACM Computing Surveys*, vol. 55, no. 12, p. Article 248, 2023.
- [16] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, and M. Fritz, “Not what you’ve signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection,” *arXiv preprint arXiv:2302.12173*, 2023, presented at ACM AISec ’23. [Online]. Available: <https://arxiv.org/abs/2302.12173>
- [17] Y. Liu, Y. Jia, R. Geng, J. Jia, and N. Z. Gong, “Formalizing and benchmarking prompt injection attacks and defenses,” in *Proceedings of the 33rd USENIX Security Symposium*. USENIX Association, 2024, pp. 1831–1847. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity24/presentation/liu-yupe>
- [18] A. Zou, Z. Wang, N. Carlini, M. Nasr, J. Z. Kolter, and M. Fredrikson, “Universal and transferable adversarial attacks on aligned language models,” *arXiv preprint arXiv:2307.15043*, 2023. [Online]. Available: <https://arxiv.org/abs/2307.15043>
- [19] OWASP Foundation, “OWASP top 10 for agentic applications,” Dec. 2025. [Online]. Available: <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications/>
- [20] IBM Security and Ponemon Institute, “Cost of a data breach report 2025,” 2025, the AI Oversight Gap edition. [Online]. Available: <https://www.ibm.com/think/x-force/2025-cost-of-a-data-breach-navigating-ai>
- [21] ENISA, “Multilayer framework for good cybersecurity practices for AI,” Jun. 2023. [Online]. Available: <https://www.enisa.europa.eu/publications/multilayer-framework-for-good-cybersecurity-practices-for-ai>
- [22] Y. Ge, “Governance architecture for autonomous agent systems: Threats, framework, and engineering practice,” *arXiv preprint arXiv:2603.07191*, 2026, layered Governance Architecture (LGA): four-layer framework with execution sandboxing (L1), intent verification (L2), zero-trust inter-agent authorization (L3), and immutable audit logging (L4). Bilingual benchmark of 1,081 tool-call samples; intent verification intercepts 93.0–98.5% of malicious tool calls across five LLM judges. [Online]. Available: <https://arxiv.org/abs/2603.07191>
- [23] NIST, “Artificial intelligence risk management framework (AI RMF 1.0),” National Institute of Standards and Technology, Tech. Rep. NIST AI 100-1, Jan. 2023. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/ai/nist.ai.100-1.pdf>
- [24] ISO/IEC, “ISO/IEC 42001:2023 – information technology – artificial intelligence – management system,” 2023. [Online]. Available: <https://www.iso.org/standard/42001>
- [25] Brasil, “Lei nº 13.709, de 14 de agosto de 2018 – lei geral de proteção de dados (LGPD),” 2018. [Online]. Available: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm
- [26] ANPD, “Resolução CD/ANPD nº 15, de 24 de abril de 2024 – regulamento de comunicação de incidente de segurança,” 2024. [Online]. Available: https://www.gov.br/anpd/pt-br/acao-a-informacao/institucional/atos-normativos/regulamentacoes_anpd
- [27] P. Manakul, A. Liusie, and M. J. F. Gales, “SelfCheckGPT: Zero-resource black-box hallucination detection for generative large language models,” in *Proceedings of the 2023 Conference on Empirical Methods in Natural Language Processing (EMNLP)*, 2023, pp. 9004–9017. [Online]. Available: <https://arxiv.org/abs/2303.08896>
- [28] OWASP Foundation, “Agentic AI – threats and mitigations,” 2025. [Online]. Available: <https://genai.owasp.org/resource/agentic-ai-threats-and-mitigations/>
- [29] A. Abuadbba, N. Sultan, S. Nepal, and S. Jha, “Human society-inspired approaches to agentic AI security: The 4C framework,” *arXiv preprint arXiv:2602.01942*, 2026, organizes agentic AI risks across four dimensions: Core, Connection, Cognition, Compliance. [Online]. Available: <https://arxiv.org/abs/2602.01942>
- [30] A. Kurtz and K. Krawiecka, “Who governs the machine? A machine identity governance taxonomy (MIGT) for AI systems operating across enterprise and geopolitical boundaries,” *arXiv preprint arXiv:2604.06148*, 2026, aI-Identity Risk Taxonomy (AIRT) with 37 risk subcategories across eight domains; companion Machine Identity Governance Taxonomy (MIGT). Documents agent-to-human identity ratios exceeding 80:1 in enterprise environments. [Online]. Available: <https://arxiv.org/abs/2604.06148>
- [31] NIST, “AI RMF: Generative artificial intelligence profile,” National Institute of Standards and Technology, Tech. Rep. NIST AI 600-1, Jul. 2024. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>
- [32] —, “The NIST cybersecurity framework 2.0,” National Institute of Standards and Technology, Tech. Rep. NIST CSWP 29, Feb. 2024. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>
- [33] The MITRE Corporation, “MITRE ATT&CK enterprise,” 2024, living document; accessed 2026-05-31. [Online]. Available: <https://attack.mitre.org>
- [34] —, “MITRE ATLAS – adversarial threat landscape for artificial-intelligence systems,” 2025, living document; v5.1.0, accessed 2026-05-31. [Online]. Available: <https://atlas.mitre.org>
- [35] OWASP Foundation, “OWASP top 10 for large language model applications – 2025,” 2024, v4.2.0a (Nov 2024). [Online]. Available: <https://genai.owasp.org/resource/owasp-top-10-for-llm-applications-2025/>
- [36] ISO/IEC, “ISO/IEC 27001:2022 – information security, cybersecurity and privacy protection – ISMS – requirements,” 2022. [Online]. Available: <https://www.iso.org/standard/27001>
- [37] A. R. Hevner, S. T. March, J. Park, and S. Ram, “Design science in information systems research,” *MIS Quarterly*, vol. 28, no. 1, pp. 75–105, 2004.

- [38] K. Peffers, T. Tuunanen, M. A. Rothenberger, and S. Chatterjee, "A design science research methodology for information systems research," *Journal of Management Information Systems*, vol. 24, no. 3, pp. 45–77, 2007.
- [39] M. Bhatt, S. Chennabasappa, C. Nikolaidis, S. Wan, I. Evtimov, D. Gabi, D. Song, F. Ahmad, C. Aschermann, L. Fontana, S. Frolov, R. P. Giri, D. Kapil, Y. Kozyrakis, D. LeBlanc, J. Milazzo, A. Straumann, G. Synnaeve, V. Vontimitta, S. Whaley, and J. Saxe, "Purple llama CyberSecEval: A secure coding benchmark for language models," *arXiv preprint arXiv:2312.04724*, 2023. [Online]. Available: <https://arxiv.org/abs/2312.04724>
- [40] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, "NIST SP 800-207: Zero trust architecture," National Institute of Standards and Technology, Tech. Rep. SP 800-207, Aug. 2020. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/specialpublications/NIST.SP.800-207.pdf>
- [41] F. Blefari, C. Cosentino, F. A. Pironti, A. Furfaro, and F. Marozzo, "CyberRAG: An agentic RAG cyber attack classification and reporting tool," *arXiv preprint arXiv:2507.02424*, 2025, agentic RAG framework orchestrating fine-tuned classifiers and tool adapters with iterative retrieval-and-reason loop over a domain-specific knowledge base. [Online]. Available: <https://arxiv.org/abs/2507.02424>
- [42] H. T. Neprash, C. C. McGlave, D. A. Cross *et al.*, "Trends in ransomware attacks on US hospitals, clinics, and other health care delivery organizations, 2016–2021," *JAMA Health Forum*, 2022. [Online]. Available: <https://pmc.ncbi.nlm.nih.gov/articles/PMC9856685/>
- [43] Various, "Ransomware attacks and data breaches in US health care systems," *JAMA Network Open*, 2024. [Online]. Available: <https://jamanetwork.com/journals/jamanetworkopen/fullarticle/2833984>
- [44] H. T. Neprash *et al.*, "Cybersecurity lessons from the Change Healthcare attack," *JAMA Internal Medicine*, 2024.
- [45] NSA AISC, CISA, FBI, ASD ACSC, CCCS, NCSC-NZ, and NCSC-UK, "Deploying AI systems securely: Best practices for deploying secure and resilient AI systems," National Security Agency Artificial Intelligence Security Center, Tech. Rep., Apr. 2024. [Online]. Available: <https://media.defense.gov/2024/Apr/15/2003439257/-1/-1/0/CSI-DEPLOYING-AI-SYSTEMS-SECURELY.PDF>
- [46] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, "Toward generating a new intrusion detection dataset and intrusion traffic characterization," in *Proceedings of the 4th International Conference on Information Systems Security and Privacy (ICISSP)*. SciTePress, 2018, pp. 108–116, introduces the CICIDS-2017 dataset with 14 attack categories captured over a five-day testbed and the CICFlowMeter feature set used as the schema reference for the synthetic generator in this paper.
- [47] C. Wohlin, P. Runeson, M. Höst, M. C. Ohlsson, B. Regnell, and A. Wesslén, *Experimentation in Software Engineering*. Springer, 2012.